

UNIVERSIDAD DE LAS PALMAS DE GRAN CANARIA

Escuela de Ingeniería Informática

Práctica 9:
ANÁLISIS COMPARATIVO DE
VULNERABILIDADES CVE

Asignatura: Seguridad de la Información

Curso: 4º de Grado en Ingeniería Informática

Autor:

Nicolás Rey Alonso

`nicolas.rey101@alu.ulpgc.es`

Fecha: Abril 2026

Índice general

1. Introducción	2
1.1. Objetivos de la práctica	2
1.2. Fundamentos teóricos	2
1.3. Enunciado de la práctica	3
2. CVEs	4
3. Modificación del fichero hosts	5
4. Incorporación del certificado RAÍZ	6
5. Configuración del servidor Apache	7
6. Instalación y arranque del servidor Apache	8
7. Página index.html	9
8. Conexión con openssl s_client	10
9. Conexión desde el navegador local	11
10. Capturas de Pantalla del acceso web	12

Capítulo 1

Introducción

1.1. Objetivos de la práctica

El objetivo fundamental de esta práctica es la obtenención de información y familiarización con las amenazas a la seguridad digital.

1.2. Fundamentos teóricos

Para la realización de esta práctica, se aplican diversos conceptos teóricos clave de la ciberseguridad y la seguridad de la información, entre los que destacan:

- **Conocimiento de los CVE/CWE:** CVE (Common Vulnerabilities and Exposures) es un sistema de identificación de vulnerabilidades conocido a nivel mundial, mientras que CWE (Common Weakness Enumeration) clasifica las debilidades de software. Familiarizarse con estas bases de datos es esencial para entender las amenazas actuales y cómo mitigarlas.
- **Phishing:** Técnica de ingeniería social utilizada para engañar a los usuarios y obtener información confidencial, como contraseñas o datos bancarios, a través de correos electrónicos, mensajes o sitios web falsos.
- **Malware:** Software malicioso diseñado para dañar, explotar o comprometer sistemas informáticos. Puede incluir virus, troyanos, ransomware, spyware, entre otros.
- **Ransomware:** Tipo de malware que cifra los archivos de la víctima y exige un rescate para restaurar el acceso a los datos. Es una amenaza creciente para empresas y particulares.

- **Botnets:** Redes de dispositivos comprometidos (ordenadores zombies) controlados por un atacante para realizar actividades maliciosas, como ataques DDoS, envío de spam o minería de criptomonedas.
- **SQL Injection:** Vulnerabilidad que permite a un atacante ejecutar código SQL malicioso en una base de datos a través de una aplicación web, lo que puede resultar en la exposición o manipulación de datos sensibles.
- **Cross-Site Scripting (XSS):** Vulnerabilidad que permite a un atacante inyectar scripts maliciosos en páginas web vistas por otros usuarios, lo que puede llevar al robo de cookies, secuestro

1.2.1. Enunciado:

1. Introducción a CVE, CVSS y las principales bases de datos

1.2.2. Introducción a CVE, CVSS y las principales bases de datos

El estándar CVE (Common Vulnerabilities and Exposures) consiste en un sistema de identificación y catalogación de vulnerabilidades de software y hardware. El objetivo de esta norma es suministrar un marco común para que las organizaciones, desarrolladores y profesionales de la seguridad puedan discutir, reportar y gestionar estas vulnerabilidades de manera uniforme. La gestión de CVE es coordinada principalmente por MITRE (Management of Information Technology Research and Evaluation), que establece los estándares y el marco operativo para la asignación de estos identificadores.

Por otra parte, las CNA (CVE Numbering Authorities) son organizaciones autorizadas para asignar identificadores CVE a vulnerabilidades específicas. Estas autoridades pueden ser fabricantes de software, investigadores de seguridad o entidades académicas, y su función es garantizar que cada vulnerabilidad se registre de manera precisa y rastreable. La asignación de un CVE a una vulnerabilidad implica un proceso riguroso de verificación y documentación para asegurar la integridad del sistema. Una vez que una vulnerabilidad ha sido identificada y registrada con un CVE, su impacto se cuantifica utilizando el sistema CVSS (Common Vulnerability Scoring System). CVSS es un método estandarizado que asigna una puntuación numérica (de 0.0 a 10.0) que refleja la severidad y la explotabilidad de la vulnerabilidad.

En cuanto a las principales bases de datos, existen diferencias clave: CVE.org es el registro central donde se publican y gestionan los identificadores CVE. La NVD (National Vulnerability Database), mantenida por el NIST (Instituto Nacional de Estándares y Tecnología), es una base de datos que recopila datos sobre vulnerabilidades, incluyendo puntuaciones CVSS asociadas a múltiples identificadores CVEs. Finalmente, FIRST.org (Forum of Incident Response and

Security Teams) es un foro más amplio centrado en la colaboración comunitaria, las mejores prácticas y el desarrollo de estándares de respuesta a incidentes de seguridad, aunque no es una base de datos directa de vulnerabilidades como la NVD.

1.3. Enunciado de la práctica

Esta práctica consiste en la realización de un informe basado en una selección de noticias de prensa digital, posteriores al 1 de enero de 2025, relacionadas con una serie de amenazas informáticas.

Las amenazas objeto de esta actividad serán:

1. Phishing, estafas a través de la red
2. Malware difundido en redes sociales
3. Ataques de ransomware contra corporaciones y gobiernos
4. Botnets, ordenadores zombies
5. Malware en dispositivos móviles
6. Inyección de código SQL
7. Cross-Site Scripting (XSS)

Capítulo 2

CVEs

Capítulo 3

Modificación del fichero hosts

Se modifica el fichero `/etc/hosts` para añadir los alias.

```
1 127.0.0.1 www.ejemplo.com
2 127.0.0.1 ejemplo.com
```

Verificamos:

```
1 ping -c 2 www.ejemplo.com
2 ping -c 2 ejemplo.com
```

Capítulo 4

Incorporación del certificado RAÍZ

Se incorpora el certificado RAÍZ de la asignatura a la lista de autoridades reconocidas del sistema según las instrucciones.

Capítulo 5

Configuración del servidor Apache

Descripción detallada de los ficheros modificados, donde se configuran el certificado de servidor, cliente (si fuera necesario) y la entidad CA (Autoridad de Certificación).

Capítulo 6

Instalación y arranque del servidor Apache

Comandos utilizados:

```
1 sudo apt update
2 sudo apt install apache2
3 sudo a2enmod ssl
4 sudo systemctl restart apache2
```

Se revisan continuamente `/var/log/apache2/error_log` para detectar `*warnings*` y errores; y `/var/log/apache2/access_log` para comprobar accesos.

Capítulo 7

Página index.html

Creación de la página principal en el directorio raíz del servidor y configuración de los permisos y cualquier otra modificación adicional necesaria.

Capítulo 8

Conexión con openssl s_client

Comprobación mediante openssl s_client:

```
1 openssl s_client -connect www.ejemplo.com:443
```

Se compara con al conexión a `www.ulpgc.es:443` para verificar. Así nos aseguramos de que no hay un problema de identificación del servidor y los certificados que presenta.

Capítulo 9

Conexión desde el navegador local

Se realizan pruebas con Firefox, donde deberá accederse de forma transparente, es decir, sin mostrar ningún error y sin generar avisos con la opción de "*Entiendo los riesgos*".

Capítulo 10

Capturas de Pantalla del acceso web

Se incorporarán las 4 capturas, como mínimo, que muestran la correcta configuración de la web de este servidor virtual:

- 2 capturas con el contenido para las descripciones de los dominios (ejemplo.com y www.ejemplo.com).
- 2 capturas de las propiedades de la conexión.